Email Security

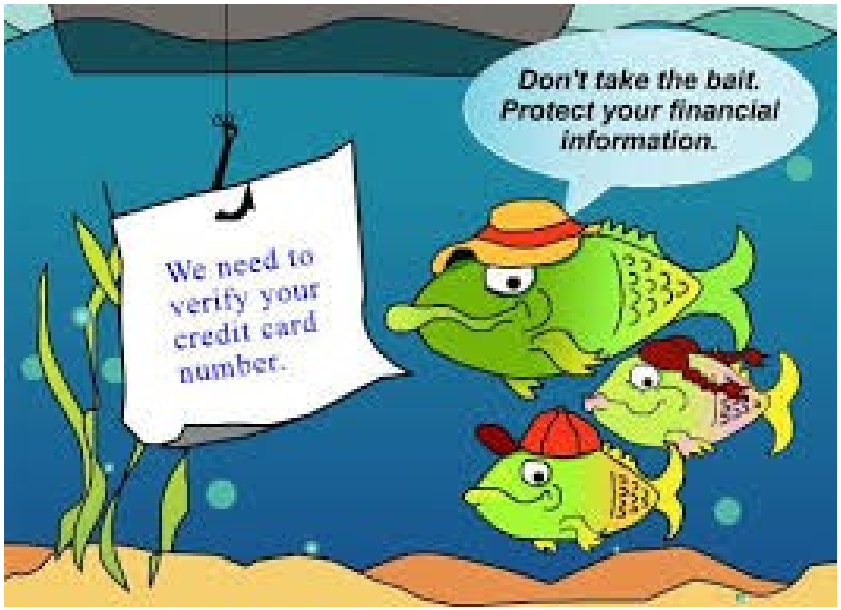
Rakesh M. Verma

ReDAS Laboratory
Computer Science Dept.
University of Houston

Emails

- Propagate over the SMTP network – a logical network of SMTP servers overlaid on the Internet
- Full header – real example given in class, a rich source of information/meta-data
- DKIM – signature for email integrity
- Sender Policy Framework (SPF) – authorized email servers in a domain

Phish Or Not is The Question



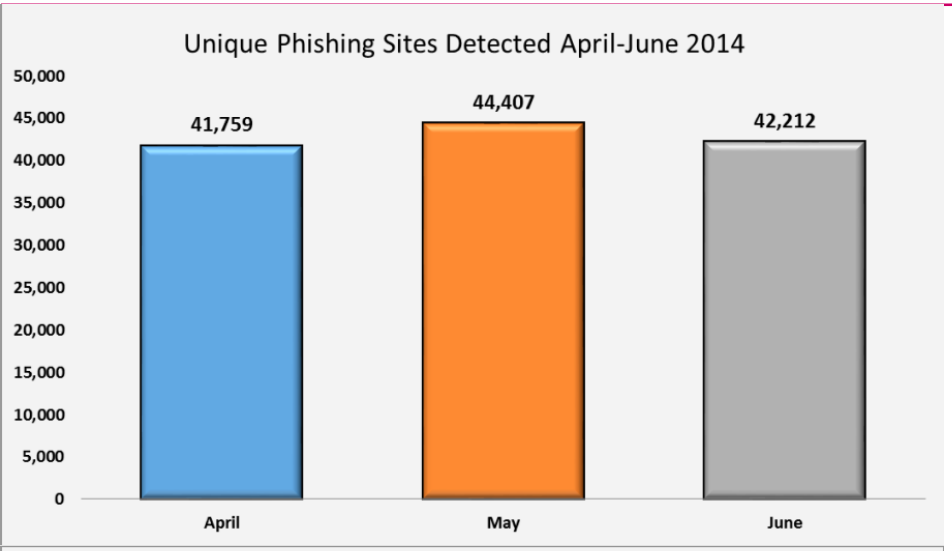
Sampling of the Email Deception Attacks Research - sources

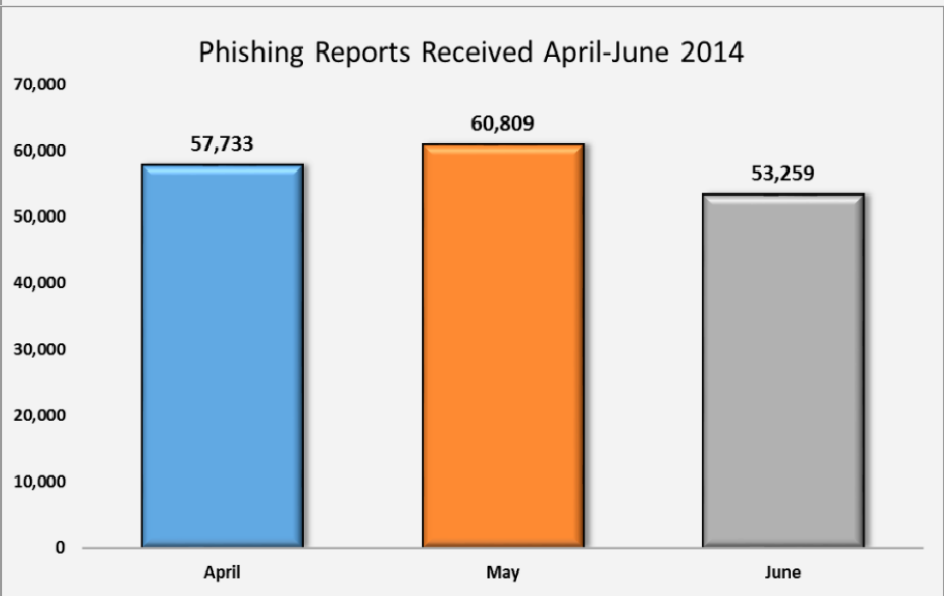
- Phishing email detection [ESORICS '12, ICISC '13, SECRYPT '15, CODASPY '17]
- Phishing URL detection [CODASPY '15, IWSPA '17]
- Phishing web site detection [ICISS '14, HICSS 2020]
- Email masquerade attacks [ASIA CCS '17]
- Phishing during disaster [IEEE ResWeek '18]
- New features: phishing email det. [ADMiS '18]

Phishing

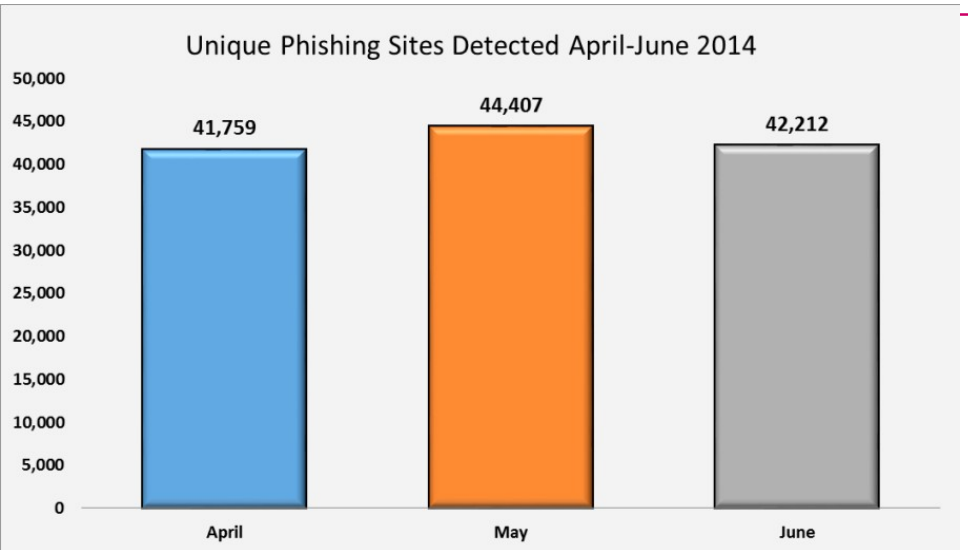
- An acute and persistent problem
- Can be used for stealing user's digital identity or to install malware through attachments (e.g. millions stolen via Trojan, attack on multiple banks)
- Estimates of losses range from a few billion dollars to tens of billions per year

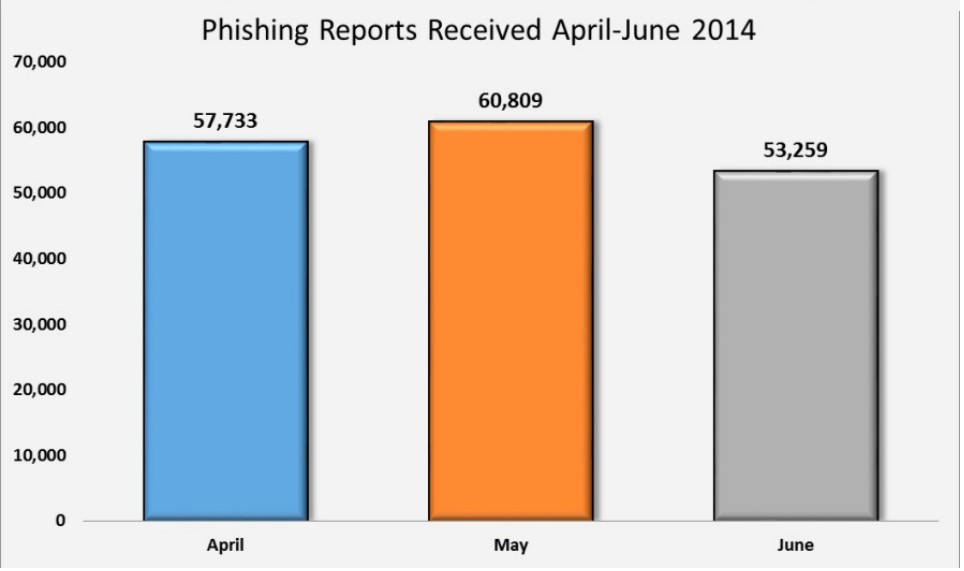
Magnitude of the Menace





- Q2 2014 data obtained from Anti Phishing Working Group (APWG)
- 2019 data is worse!





- Global estimated losses for 2014 = $3.2 Billion
  - Infragard report
- Other losses include: lost time and productivity
- Q2 2014 data from Anti Phishing Working Group (APWG)

Phishing Modus Operandi

- Email is by far the most popular medium for phishing
- Others include:
  - Web forums
  - Internet chat rooms
  - Phone conversations
  - …

I. Phishing Email Detection

- July 2011-Aug 2012: 115 phishing emails passed unmarked through my spam filter. Approx. 9/month.

Date: Tue, 13 Sep 2011 09:09:52 -0600
From: XYZ <abc@sw1.k12.wy.us>
To: undisclosed-recipients: ;
Subject: Mail Box Quota Exceeded

Your web mail quota has exceeded the set quota which is 3GB. you are
currently running on 3.9 GB.
To re-activate and increase your web mail quota please click the link
below.
<CLICK HERE>

Failure to do so may result in the cancellation of your web mail
account.
Thanks, and sorry for the inconvenience
Local-host.

Quick Victory Achievable?

"It is *non-trivial* to distinguish phishing messages from legitimate messages, since phishing messages are constructed to resemble legitimate messages as much as possible."

[Irani, Webb, Giffin, Pu – 2008]

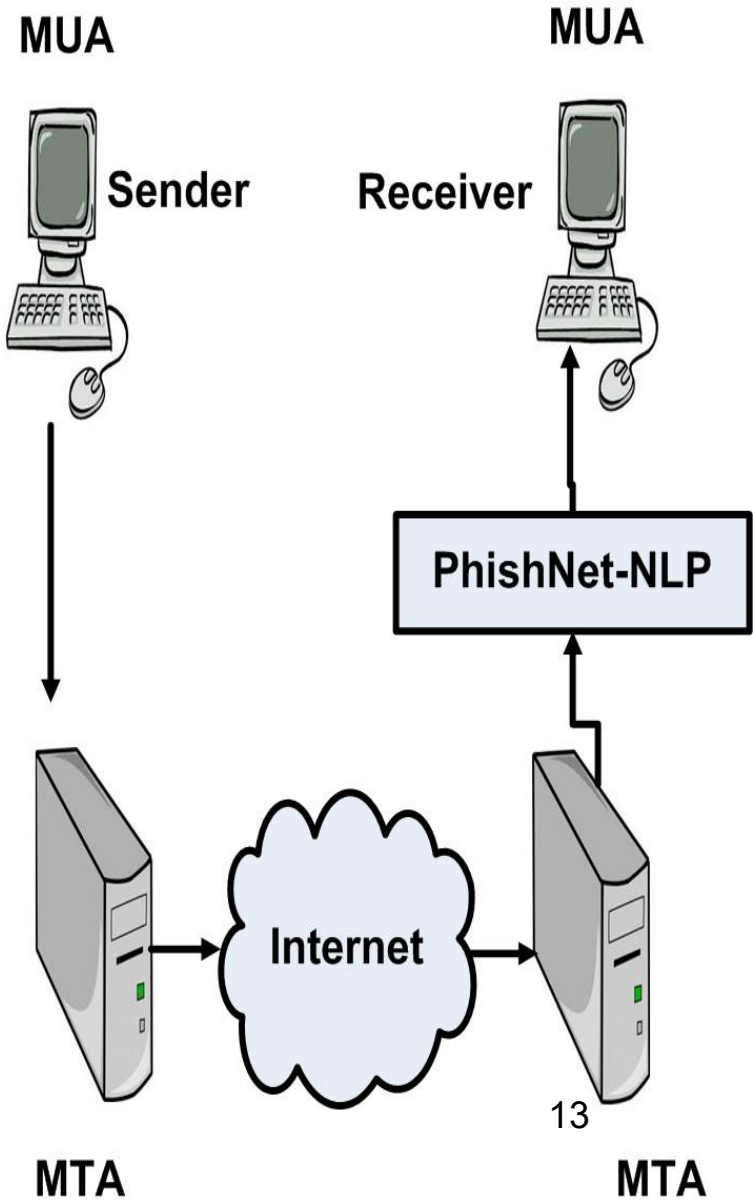
Outline of Phishing Email Detection

- Phishnet-NLP [ESORICS 2012]
- Improving the body text classifier [ICISC 2013]
- Message-Id field [SECRYPT 2015]
- Datasets
- Results and Comparison

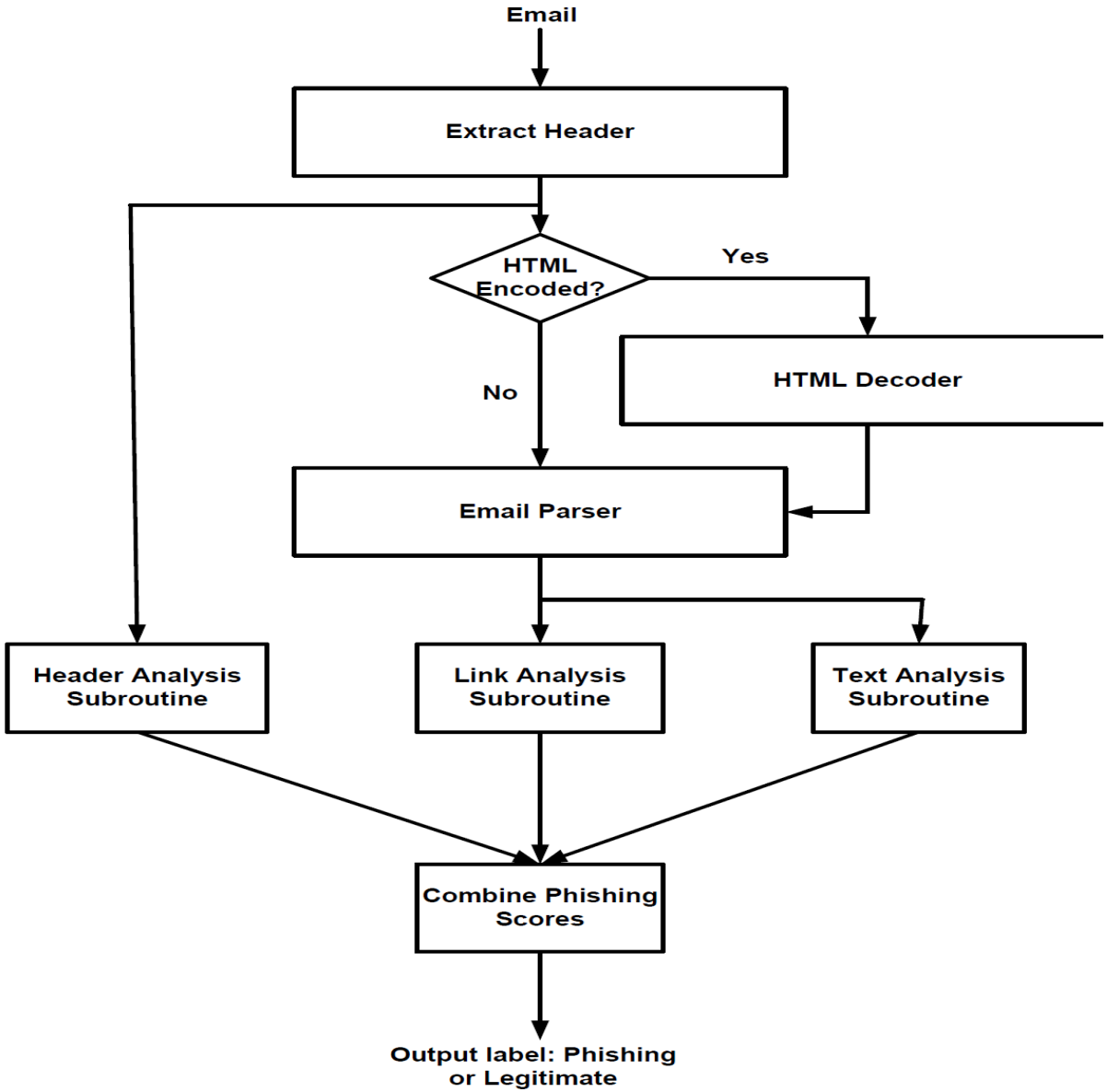
The Principle Behind Our Methods

- Focus on key differences between a phishing and a legitimate email
  - Phishing email requires user to take some action
  - Phishing email conveys a sense of urgency, or threat, or deadline, or some financial incentive for maximum reward in a short period of time

- **PhishNet-NLP** [ESORICS 2012]
  - Comprehensive approach based on three boolean classifiers:
    - Text Analysis
    - Header Analysis
    - Link Analysis
  - Combines results from each classifier to decide if email is phishing
  - Analyzes emails before reaching mailbox to prevent attack by malware
  - Use contextual information of links for efficiency
  - No training on or annotation of emails
- **Dataset**
  - 4,550 phishing emails (available online)
  - 1,000 legitimate emails (authors' mailboxes)



PhishNet-NLP Flowchart



From: Amazon.com [service@amazon.com] Sent: Mon 1/18/2010 9:00 PM
To:
Cc:
Subject: Update your Amazon.com account information.

amazon.com®

Dear Customer,

You have received this email because we have strong reason to believe that your Amazon account had been recently compromised. In order to prevent any fraudulent activity from occurring we are required to open an investigation into this matter.

- Your account is not suspended, but if in 36 hours after you receive this message your account is not confirmed we reserve the right to terminate your Amazon subscription.
- If you received this notice and you are not an authorized Amazon account holder, please be aware that it is in violation of Amazon policy to represent oneself as an Amazon user. Such action may also be in violation of local, national, and/or international law.
- Amazon is committed to assist law enforcement with any inquires related to attempts to misappropriate personal information with the intent to commit fraud or theft.
- Information will be provided at the request of law enforcement agencies to ensure that perpetrators are prosecuted to the full extent of the law.

To confirm your identity with us click the link bellow:
http://www.amazon.com/exec/obidos/sign-in.html

We apologize in advance for any inconvenience this may cause you and we would like to thank you for your cooperation as we review this matter.

Example

Phishing Email

From: Amazon.com [service@amazon.com] Sent: Mon 1/18/2010 9:00 PM
To:
Cc:
Subject: Update your Amazon.com account information.

amazon.com®

Dear Customer,

You have received this email because we have strong reason to believe that your Amazon account had been recently compromised. In order to prevent any fraudulent activity from occurring we are required to open an investigation into this matter.

- Your account is not suspended, but if in 36 hours after you receive this message your account is not confirmed we reserve the right to terminate your Amazon subscription.
- If you received this notice and you are not an authorized Amazon account holder, please be aware that it is in violation of Amazon policy to represent oneself as an Amazon user. Such action may also be in violation of local, national, and/or international law.
- Amazon is committed to assist law enforcement with any inquires related to attempts to misappropriate personal information with the intent to commit fraud or theft.
- Information will be provided at the request of law enforcement agencies to ensure that perpetrators are prosecuted to the full extent of the law.

To confirm your identity with us click the link bellow:
http://www.amazon.com/exec/obidos/sign-in.html

We apologize in advance for any inconvenience this may cause you and we would like to thank you for your cooperation as we review this matter.

Example

Phishing Email

Fraudulent Link

From: Amazon.com [service@amazon.com] Sent: Mon 1/18/2010 9:00 PM
To:
Cc:
Subject: Update your Amazon.com account information.

amazon.com®

Dear Customer,

You have received this email because we have strong reason to believe that your Amazon account had been recently compromised. In order to prevent any fraudulent activity from occurring we are required to open an investigation into this matter.

- Your account is not suspended, but if in 36 hours after you receive this message your account is not confirmed we reserve the right to terminate your Amazon subscription.
- If you received this notice and you are not an authorized Amazon account holder, please be aware that it is in violation of Amazon policy to represent oneself as an Amazon user. Such action may also be in violation of local, national, and/or international law.
- Amazon is committed to assist law enforcement with any inquires related to attempts to misappropriate personal information with the intent to commit fraud or theft.
- Information will be provided at the request of law enforcement agencies to ensure that perpetrators are prosecuted to the full extent of the law.

To confirm your identity with us click the link bellow:
http://www.amazon.com/exec/obidos/sign-in.html

We apologize in advance for any inconvenience this may cause you and we would like to thank you for your cooperation as we review this matter.

Example

Phishing Email

Fraudulent Link

NLP-based Detection

- Natural Language Processing is challenging
- Natural languages have polysemous words, collocations, ambiguity, exceptions, …
- One needs a little knowledge of the world to understand the meaning of a single sentence

Vol. 166 No. 41 ★ ★ ★ Thursday

RED TAPE HOLDS UP NEW BRIDGE

AND MORE FLUBS FROM THE NATION'S PRESS

Edited by Gloria Cooper | Collected by the Columbia Journalism Review

A Translation Experiment

Input	Output
Computers are not good at crunching text	**컴퓨터가 텍스트를 재정에서 잘되지 않습니다**
컴퓨터가 텍스트를 재정에서 잘되지 않습니다	Текст, компьютер не знает финансовый
Текст, компьютер не знает финансовый	ைஉ ர , க ண (ன * நி தி ெ த / யா 2
ைஉ ர , க ண (ன * நி தி ெ த / யா 2	Text, the system does not fund in the

With Chinese replacing Korean experiment we get?

The text is not very good mathematical systems - 2012

On 4/13/2017 at 4.10am Chennai local time

Input	Output
Computers are not good at crunching text	**컴퓨터가 텍스트를 잘 처리하지 못함**
컴퓨터가 텍스트를 잘 처리하지못함	Ошибка компьютера совладать текст
Ошибка компьютера совладать текст	கண#ன%& ()சிையய. க / 0 & பா 0 ைஉர
கண#ன%& ()சிையய. க / 0 & பா 0 ைஉர	Computer bug control speech

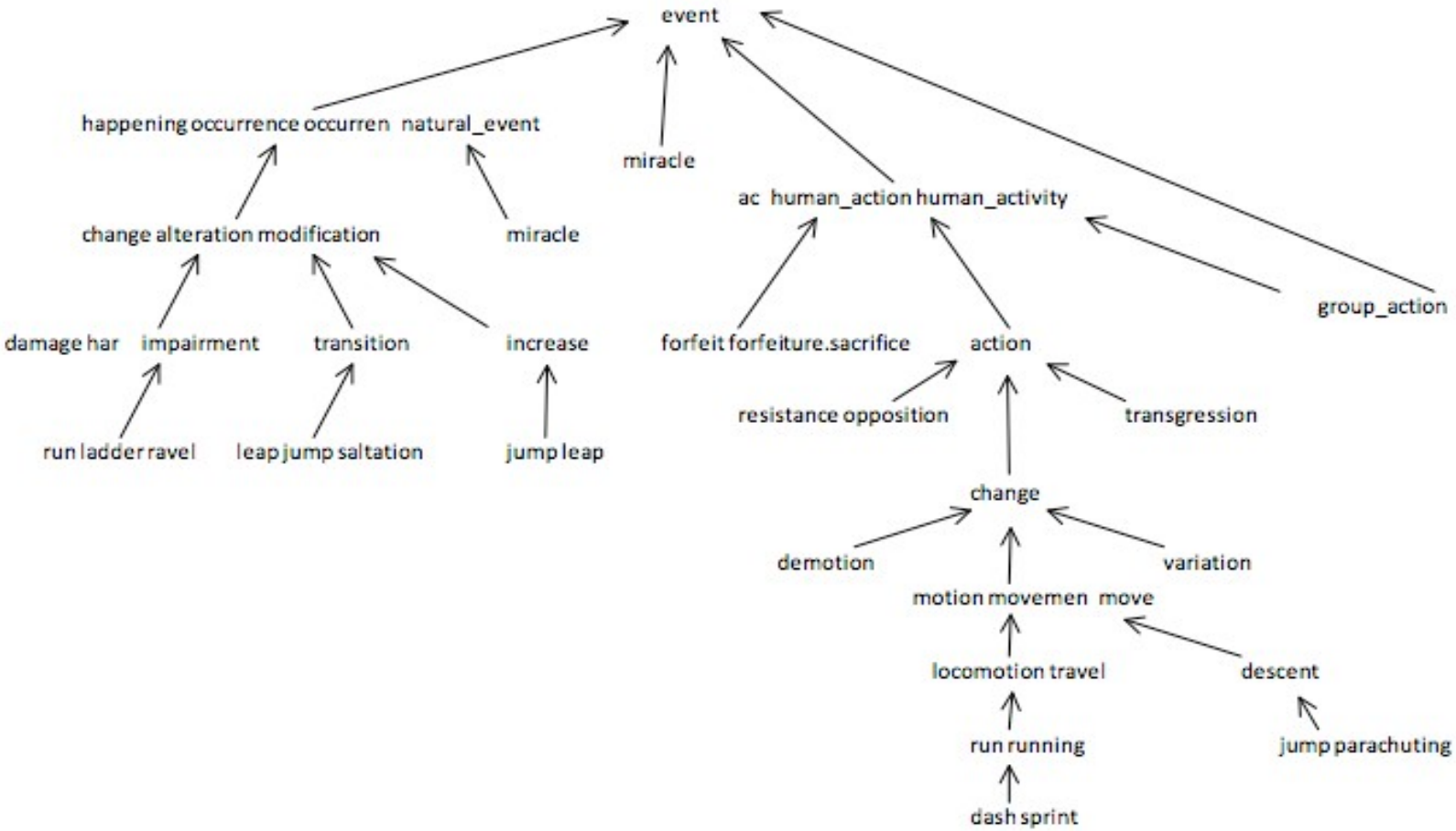
NLP Background

- NLP techniques used
  1. Named-entity extraction (proper noun phrases that denote: person, place, organization, date, or money)

     Bob bought a book at Amazon for 20 dollars.
  1. Part-of-speech (POS) tagging

     Alice/NNP emailed/VBD the/DT certificate/NN.
  2. Word-sense disambiguation for polysemous words Alice *gets (gets/VB/#17)* it. The question got (got/VBD/#33) me.
  3. Stop word removal (removal of function words such as a, an, the, etc.)
  4. WordNet (lexical database of English, needs word + POS + sense)

WordNet Subgraph



Phishnet-NLP : Text Analysis

- Extracts text from email
- Uses NLP Techniques
  1. Part-of-speech tagging
  2. Word-sense disambiguation for polysemous verbs

     (Example: John *gets* it, The child *got* scared, Bob got a speeding ticket)

  3. Stemming
  4. WordNet (needs part-of-speech, stem and sense)
- Scores certain *verbs*, takes maximum score and compares with threshold (set to 1)
  - Score increased with link, urgency, or incentive in same sentence

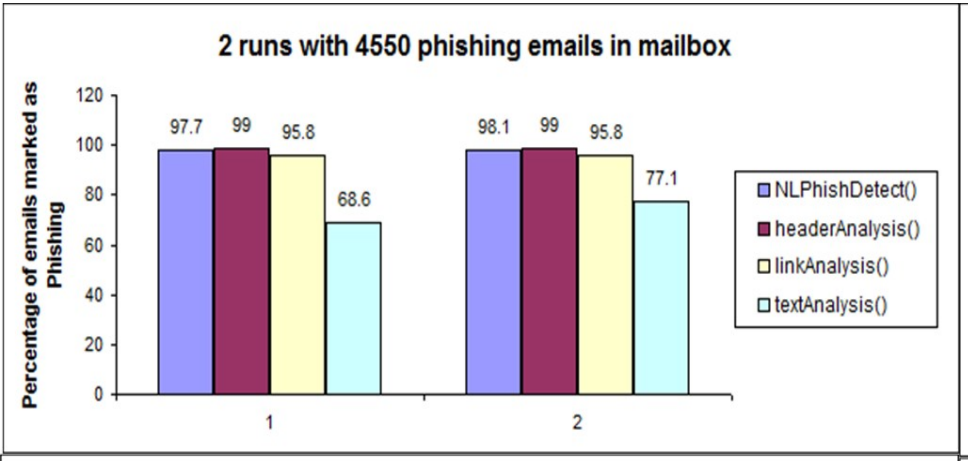
- Semantics
  - ➢ Uses *hyponymy* relation on verbs

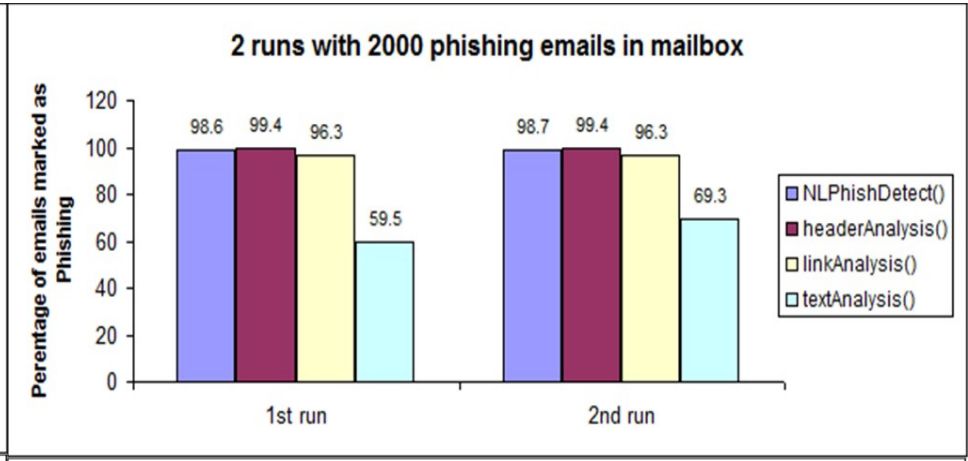
  (Example: verb click is a hyponym of verb move)
- Uses context (user's sent/recd. mail) when available
  - Increases robustness provided phisher does not have access to context
  - Increases detection
- Email scored for similarity and assigned a context-score
- Text score and Context-score combined logically

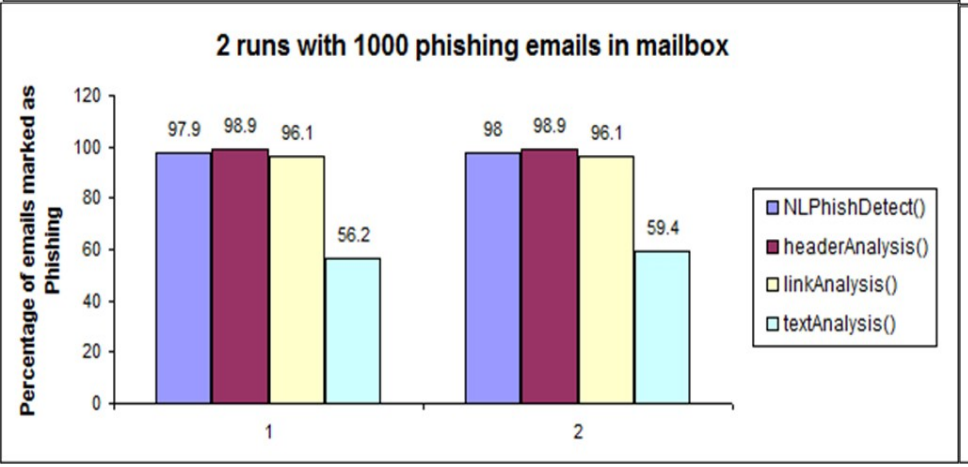
Phishnet-NLP : Context Score

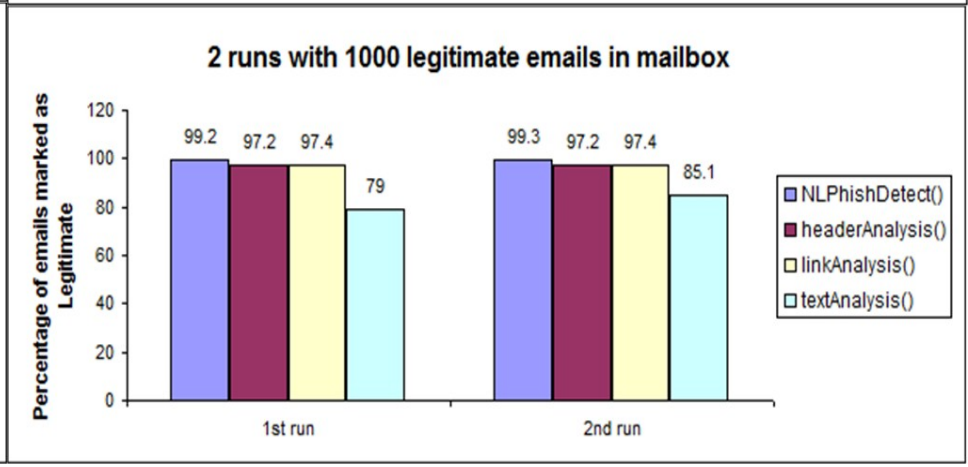
- Email converted to vector using Information Retrieval techniques
  - **TF-IDF**: Term Frequency-Inverse Document Frequency
  - **TF**: No. of occurrences of a word within a document
  - **IDF**: measure of how infrequently the word appears in other documents in the database
- Similarity score: Cosine of the angle between vectors
- Thresholding

Phishnet-NLP: Results









Improving Text Analysis: Goals

- We investigate 2 basic questions:
  - Can statistical NLP techniques be used effectively for email text analysis?
  - Do NLP techniques such as part-of-speech tagging and semantics help improve the statistical methods, and if so, by how much?

Text Analysis Comparison

- Extracts text from email
- Uses NLP techniques
- Intuitive approach: Scored certain *verbs*, took maximum score and compared with a threshold
  - Score increased with link, urgency, or incentive in same sentence
- Statistical approach: New, more accurate text-based classifiers based on semantic feature selection with t-test

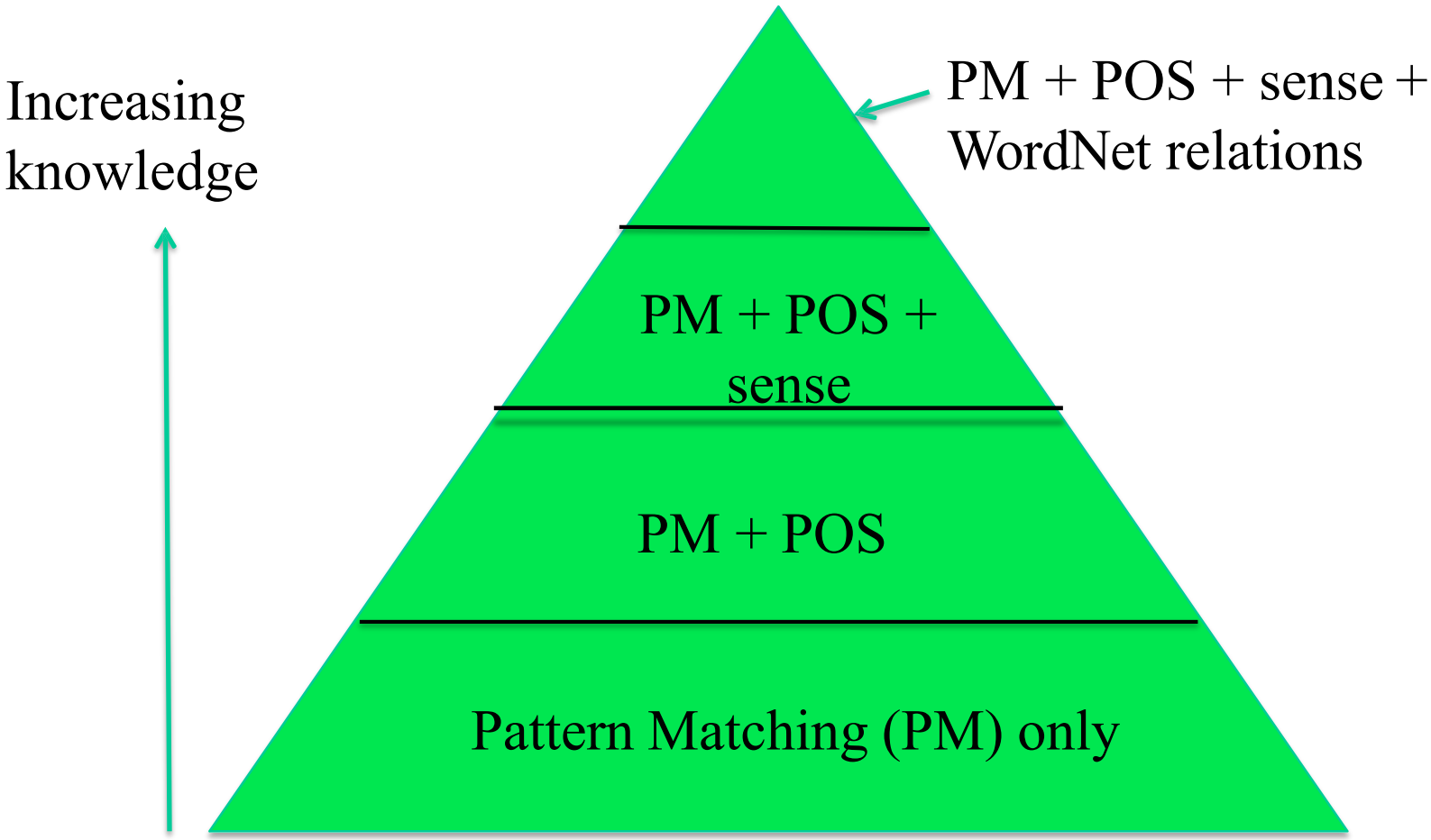
Additional Contributions

- Semantic feature selection for text data
- Careful study of feature selection with increasing “knowledge”
- Testing on bigger public datasets with more variety
- Detailed comparison of statistical versus intuitive approach on same phishing dataset

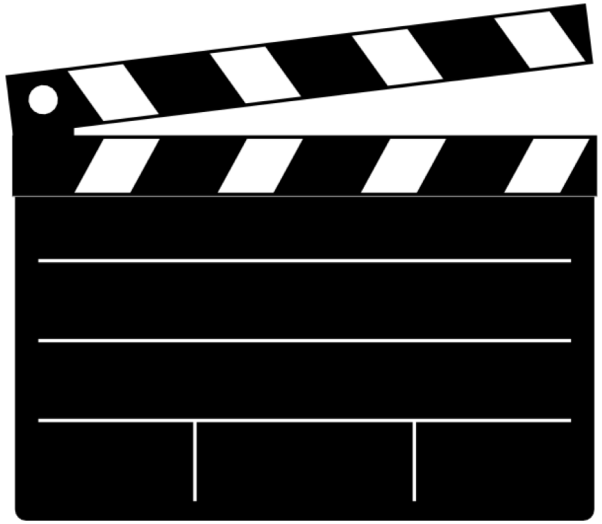
Semantic Feature Selection for Text

- Feature selection is difficult
  - Type: Filters, wrappers, hybrid
  - Too many methods: frequency-based, chi-square, information gain, mutual information, …
- We propose simple, robust and effective method based on semantics with t-test
- T-test: popular, easy to understand
- We use the 2-sample, unequal variance, 2-tailed test and look for statistically significant differences

Classifiers



Pattern Matching Classifier



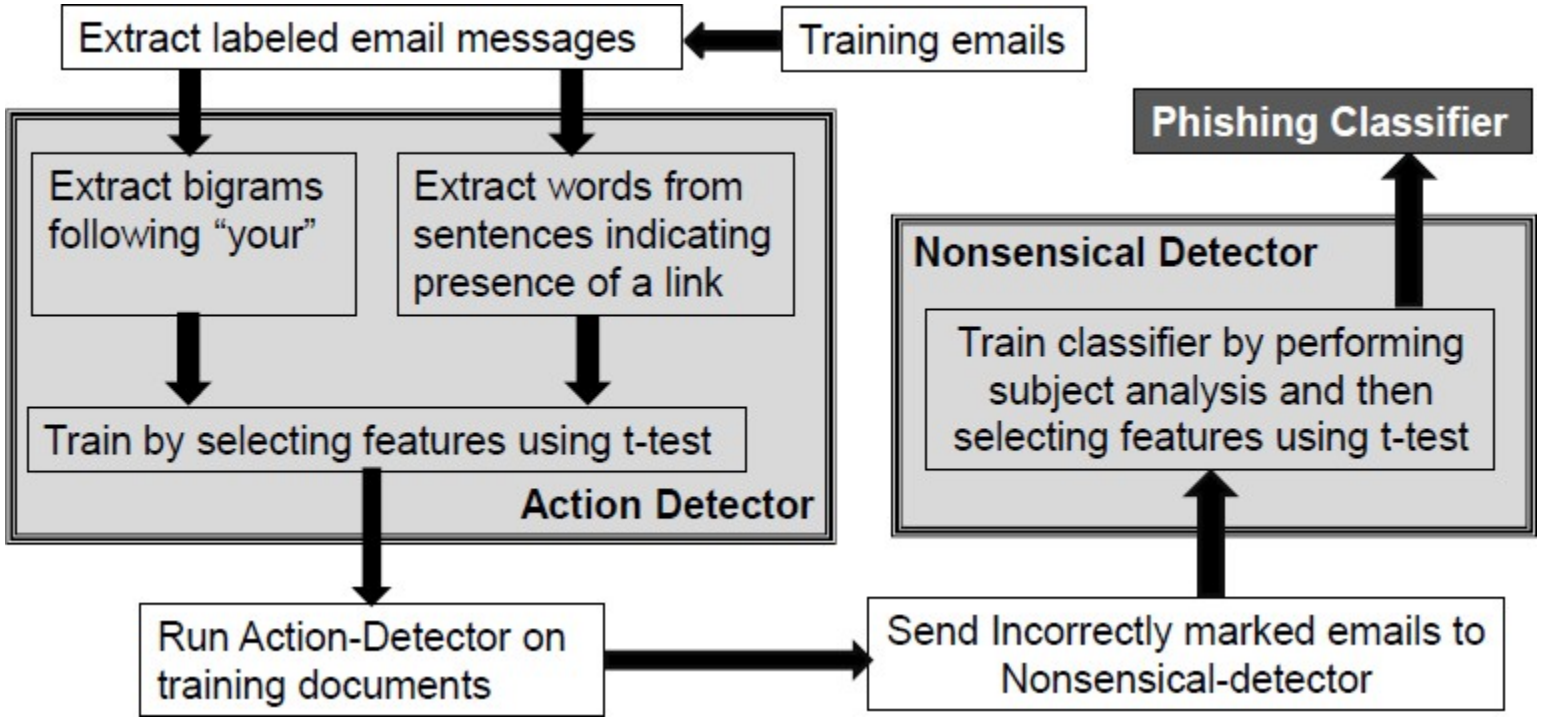
+

Detector

+ …

Detector

Flowchart of Training



Datasets

- Phishing: 4,550 emails [same as in ESORICS 2012]
- Legitimate emails: 10,000 emails from public Enron Inbox email database + 4,000 emails from Enron Sent Mail boxes
- Dataset divided into:
  - training (70% of phishing and Inbox emails)
  - testing (remaining 30% of phishing, remaining inbox, and 100% of sent emails)

Results

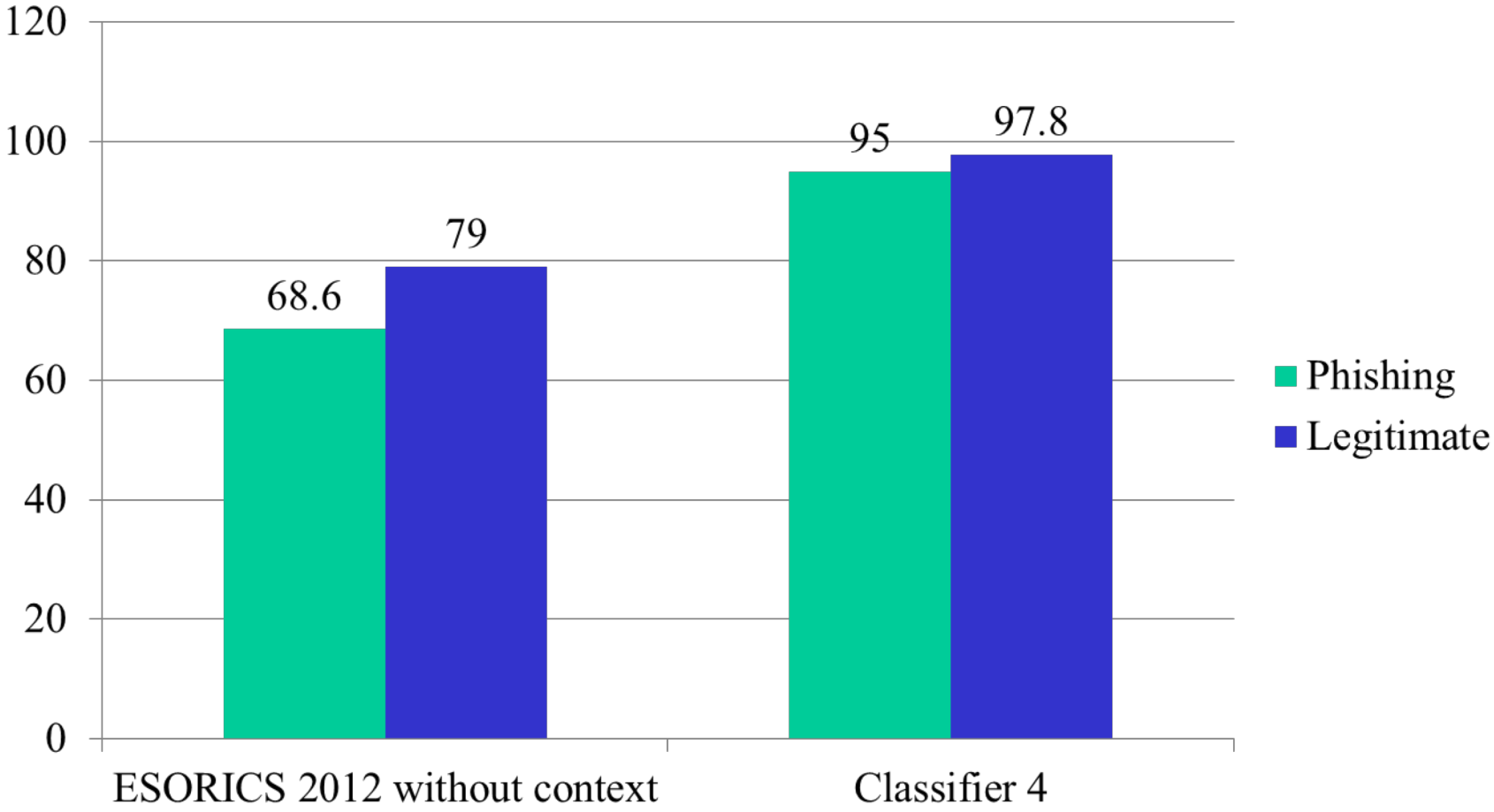
P - Phishing testing data set

I – legitimate testing data set (Inbox)

S – all legitimate sent emails (no training was done on this)

Classifier	*P*	*I*	*S*
Classifier 1	**92.88**	**4.96**	**4.17**
Action-Detector	73.6	1.92	1.96
Nonsensical-Detector	12.84	2.87	2.21
Other	6.44	0.17	0
Classifier 2	**92.01**	**4.88**	**3.9**
Action-Detector	72.23	1.4	1.76
Nonsensical-Detector	13.34	3.31	2.14
Other	6.44	0.17	0
Classifier 3	**94.8**	**2.16**	**2.37**
Action-Detector	75.1	0.5	0.72
Nonsensical-Detector	13.3	1.49	1.65
Other	6.44	0.17	0
Classifier 4	**95.02**	**2.24**	**2.42**
Action-Detector	75.82	0.57	0.77
Nonsensical-Detector	12.74	1.5	1.65
Other	6.44	0.17	0

Text Analysis Comparison



Conclusions, Future Work

- A sampling of robust schemes for email attacks
- Much scope for work in security analytics = adaptations of data analytics for security
- The best is yet to come … but it will require hard work and more sharing/collaboration

Some Pointers for More Reading

- Security Analytics: Essential Knowledge for Cyber Security Professionals and Students [IEEE Security and Privacy, Nov/Dec, 2015]
- Data Mining [Steinbach et al.]
- Machine Learning [Mitchell; Bishop]
- Foundations of Statistical NLP [Manning & Schutze]